

Tool: Compliance Checklist — UU PDP / GDPR / PCI-DSS

Apa: checklist kepatuhan regulasi eksternal untuk fitur yang sentuh data pribadi / payment. **Hard gate — gak ada bypass.** **Kapan dipake:** tiap fitur collect/store/process/transfer PII atau data pembayaran (SOP-SK-03). **Framework:** MEA03 (Owner), UU PDP (UU 27/2022), GDPR, PCI-DSS, ISO/IEC 27001, Data SACRED.

Step 0 — Scoping

- **Data classification:** Public / Internal / **PII / Sensitive PII**
- **Lineage:** origin → transform → storage → consume
- **Regulasi applicable:** produk Indo + PII → **UU PDP** · user EU → GDPR · payment → PCI-DSS · enterprise → ISO 27001
- Kalau gak ada PII/payment → **assessment N/A, catat alasan, stop.**

A. UU PDP (UU 27/2022) — primary produk Indo

- ☐ **Consent eksplisit** untuk tiap PII processing (opt-in aktif, bukan pre-checked)
- ☐ **Hak subjek data** — akses, koreksi, hapus tersedia & ada flow-nya
- ☐ **Tujuan pemrosesan** dinyatakan jelas (purpose limitation)
- ☐ **Breach notification** mechanism (lapor pemilik + otoritas tanpa tunda wajar)
- ☐ **DPO** — perlu kalau pemrosesan PII skala besar / sistematis / data sensitif
- ☐ **Cross-border transfer** — assessment kalau infra/vendor di luar Indo
- ☐ **Retention policy** jelas + **soft delete** (Data SACRED, no hard delete)
- ☐ **Data minimization** — collect hanya yang perlu

B. GDPR (kalau ada user EU)

- ☐ Consent + lawful basis · ☐ DPO (kalau wajib) · ☐ Breach notif **72 jam** · ☐ DPIA untuk high-risk · ☐ Right to portability

C. PCI-DSS (kalau payment)

- ☐ **Jangan simpan PAN/CVV** di sistem sendiri
- ☐ Pakai **gateway tersertifikasi** (Stripe/Midtrans handle most) → scope **SAQ-A** (paling ringan)
- ☐ TLS untuk transmisi · ☐ Tokenization, bukan raw card

D. Audit trail (Data SACRED — kontrol SK-C6)

- [] **Who** — user_id + role • [] **When** — timestamp UTC • [] **What** — action + resource + before/after • [] **Why** — context/reason • [] **No hard delete** (soft delete only)

E. Risk assessment

Risk	Likelihood (L/M/H)	Impact (L/M/H)	Mitigation

F. Verdict & severity

-  **Critical** (PII tanpa consent / payment tanpa PCI scope) → **escalate ≤1 hari, block sampai mitigasi**
-  **Major** (cross-border / retention unclear) → flag Tata + Kakashi
-  **Minor** (dok kurang) → catat, fix sebelum live

VERDICT: compliant / compliant-with-constraint / non-compliant

CONTOH TERISI (proyek contoh)

Compliance Assessment – Fitur Payment Digital + Signup /daftar

Step 0 – Scoping

- Data: nama, email, no HP (PII) + nominal transfer + akun bank (Sensitive)
- Regulasi: UU PDP (PII WNI) + PCI-DSS (payment)

A. UU PDP

- [x] Consent eksplisit di /daftar –  BELUM ADA flow →  red-flag
- [x] Soft delete (Data SACRED) – OK by design
- [] Cross-border – infra lokal, aman

C. PCI-DSS (payment)

- [x] Pakai Midtrans (tersertifikasi) → scope SAQ-A 
- [x] Jangan simpan kartu – gateway handle 
-  Kalau bangun payment sendiri → > 3 dev-month + PCI full → BUY (gateway), bukan build

F. Verdict

-  Signup /daftar: NON-COMPLIANT sampai consent flow ada → ESCALATE (SK-C4)
-  Payment via Midtrans: COMPLIANT (SAQ-A), asal gak simpan card

Hasil: assessment nangkap 2 hal **sebelum** live — (1) /daftar butuh consent flow UU PDP (red-flag, escalate), (2) payment **BUY gateway** bukan build (PCI full = > 3 dev-month, build-vs-buy → buy).

Action: draft consent UX bareng @bulma, integrasi Midtrans bareng @saitama. **Compliance = gate, ketahuan sebelum, bukan sesudah.**